

PART I – WHY FEDERAL ACTIVE DIRECTORY DOMAINS AND NETWORKS ARE DIFFERENT

CHAPTER 2. GOVERNING FICAM BODIES

CHAPTER ABSTRACT

This chapter introduces the federal organizations, laws, directives, mandates, frameworks, and governing authorities that shape federal cybersecurity, identity management, and Active Directory FICAM security throughout federal enterprises. Readers will learn how federal cybersecurity policy flows from legislative and executive mandates through standards organizations, operational commands, assessment authorities, and implementation teams. Understanding these governance structures is essential for cybersecurity professionals responsible for designing, assessing, defending, or operating Active Directory and FICAM infrastructure within the federal government.

Federal cybersecurity programs operate within a highly structured governance ecosystem consisting of legislative mandates, executive directives, regulatory authorities, standards organizations, operational commands, and assessment bodies. Unlike commercial enterprises, federal organizations must adhere to and align cybersecurity operations with statutory requirements, risk management processes, compliance frameworks, and Command mission assurance objectives established and set forth by numerous oversight entities and authoritative bodies.

Identity systems – including Active Directory, Active Directory Certificate Services (AD CS), Active Directory Federation Services (AD FS), Public Key Infrastructure (PKI), and Federal Identity, Credential, and Access Management (FICAM) programs – are directly influenced by these governance structures. Every decision involving authentication, authorization, privileged access, system and domain hardening, monitoring, logging, and incident response are frequently derived from federal policies, National Institute of Standards and Technology (NIST) guidance, DoD Directives, Presidential Executive Orders (EOs), DISA STIG security baselines and benchmarks, and operational requirements established by federal authorities.

This chapter examines the federal cybersecurity governance landscape and explains how federal agencies, organizations, and military branches such as Congress, Office of Management and Budget (OMB), National Institute of Standards and Technology (NIST), Cybersecurity and Infrastructure Security Agency (CISA), the Department of Defense (DoD) Chief Information Officer (CIO), the Department of Navy (DoN) Chief Information Officer (CIO), Defense Information Systems Agency (DISA), National Security Agency (NSA), United States Cyber Command (USCYBERCOM), Joint-Force Headquarters-Department of Defense Information Network (JFHQ-DoDIN), FedRAMP, the Army, and the Air Force influence cybersecurity and identity management decisions. Readers will gain an understanding of how federal laws become policies, how policies become technical controls, and how technical controls ultimately affect Active Directory security engineering firsthand, and operational readiness across federal and military enterprises.

LEARNING OBJECTIVES

Upon completion of this chapter, readers will be able to:

- Explain the federal cybersecurity governance hierarchy.
- Identify major federal cybersecurity regulatory authorities.
- Describe how federal laws influence identity security programs.
- Understand the relationship between FISMA, RMF, and NIST guidance.
- Explain how federal cybersecurity policies affect Active Directory security.
- Describe the role of operational organizations and Commands responsible for

defending federal network infrastructure.

- Understand how governance requirements translate into technical security controls.
- Recognize the connection between identity security and mission assurance.

CHAPTER STRUCTURE

2.1 Understanding Federal Cybersecurity Governance

- 2.1.1 Governance Versus Operations
- 2.1.2 Governance Versus Compliance
- 2.1.3 Governance Versus Risk Management
- 2.1.4 How Federal Cybersecurity Authority Flows Through Government and Military Bodies

2.1.5 Legislative, Executive, Regulatory, and Operational Authorities

2.1.6 Why Governance Directly Correlates with Overall Active Directory Security Posture

2.2 Federal Laws Driving Cybersecurity and Federal Identity Security Programs

- 2.2.1 The Federal Information Security Modernization Act (FISMA)
- 2.2.2 Homeland Security Act Authorities
- 2.2.3 Clinger-Cohen Act and Information Technology (IT) Governance
- 2.2.4 Federal Privacy and Data Protection Requirements
- 2.2.5 National Security System (NSS) Authorities
- 2.2.6 Legislative Drivers Behind Federal Identity Security Programs
- 2.2.7 How Federal Laws Influence Active Directory Security Requirements

2.3 Executive Branch Cybersecurity Leadership

- 2.3.1 The White House, National Cybersecurity Strategy, and HSPD-12
- 2.3.2 Executive Orders (EOs) and Cybersecurity Modernization
- 2.3.3 Office of Management and Budget (OMB)
- 2.3.4 OMB Memoranda Affecting Federal Identity Programs
- 2.3.5 Federal Zero Trust Strategy
- 2.3.6 Executive-Level Cybersecurity Accountability
- 2.3.7 Influence on Agency Identity Architecture

2.4 National Institute of Standards and Technology (NIST)

- 2.4.1 NISTs Role in Federal Cybersecurity
- 2.4.2 Development of Security Standards and Guidelines for Federal Information Systems (FIS)

- 2.4.3 NIST Special Publications (SPs)
- 2.4.4 NIST Cybersecurity Framework (NIST CSF)
- 2.4.5 NIST Digital Identity Guidance
- 2.4.6 Security Control Development, and Security Testing and Evaluation (ST&E)

- 2.4.7 NISTs Influence on Active Directory Engineering Decision-Making

2.5 Cybersecurity and Infrastructure Security Agency (CISA)

- 2.5.1 CISAs Federal Cybersecurity Mission
- 2.5.2 Protection of Federal Civilian Executive Branch System
- 2.5.3 Binding Operational Directives (BODs)
- 2.5.4 Known Exploited Vulnerabilities (KEV) Program
- 2.5.5 Federal Incident Reporting Requirements
- 2.5.6 CISA Guidance for Identity Security
- 2.5.7 CISAs Role in Federal Active Directory Defense

2.6 Department of Defense (DoD) Cybersecurity Governance

- 2.6.1 Department of Defense Cybersecurity Structure

- 2.6.2 Office of the DoD Chief Information Officer (DoD CIO)
- 2.6.3 DoD Cybersecurity Policy and Procedures Development
- 2.6.4 DoD Information Enterprise Architecture
- 2.6.5 Cyber Workforce Responsibilities
- 2.6.6 Identity and Access Management Governance Within DoD Enclaves
- 2.6.7 Influence on Active Directory and FICAM Programs
- 2.7 Defense Information Systems Agency (DISA)
 - 2.7.1 DISAs Role in Federal Cybersecurity
 - 2.7.2 Security Technical Implementation Guides (STIGs)
 - 2.7.3 Security Requirements Guides (SRGs)
 - 2.7.4 Secure Configuration Baselines
 - 2.7.5 Compliance Validation and Assessment Support
 - 2.7.6 Enterprise Services and Shared Security Infrastructure
 - 2.7.7 How DISA Guidance Shapes Federal and Military Active Directory
- Security
- 2.8 National Security Agency (NSA)
 - 2.8.1 NSAs Cybersecurity Mission and Statement
 - 2.8.2 National Security Systems (NSS) Guidance
 - 2.8.3 NSA Hardening Guidance
 - 2.8.4 Identity Security Recommendations
 - 2.8.5 Privileged Access Security Governance
 - 2.8.6 Zero Trust and Identity-Centric Security Initiatives
 - 2.8.7 NSA Contributions to Federal and Military Identity Security
- 2.9 United States Cyber Command and Defensive Cyber Operations
 - 2.9.1 United States Cyber Command (USCYBERCOM) Overview
 - 2.9.2 Defensive Cyber Operations
 - 2.9.3 Offensive Cyber Operations
 - 2.9.4 Cyber Mission Forces
 - 2.9.5 Protection of Critical Cyber Terrain
 - 2.9.6 Operational Relevance of Identity Infrastructure
 - 2.9.7 Identity Systems as Operational Objectives
- 2.10 Joint Force Headquarters-Department of Defense Information Network (JFHQ-DoDIN)
 - 2.10.1 Mission and Responsibilities
 - 2.10.2 DoDIN Operations
 - 2.10.3 Operational Readiness Assessments
 - 2.10.4 Cyber Operational Readiness Assessment (CORA)
 - 2.10.5 Cyber Readiness Metrics
 - 2.10.6 Enterprise Vulnerability and Patch Management Cadence
 - 2.10.7 Identity Infrastructure and DoDIN Defense
- 2.11 Federal Identity Governance and FICAM Authorities
 - 2.11.1 Origins of Federal Identity Governance
 - 2.11.2 Federal ICAM Roadmaps
 - 2.11.3 FICAM Governance Structures
 - 2.11.4 Identity Lifecycle Governance
 - 2.11.5 Credential Lifecycle Governance
 - 2.11.6 Federation Governance
 - 2.11.7 Trust Framework Governance
 - 2.11.8 How Governance Influences Federal and Military Active Directory
- Architecture
- 2.12 FedRAMP and Cloud Identity Governance

- 2.12.1 Origins of FedRAMP
- 2.12.2 Authorization Requirements
- 2.12.3 Shared Responsibility Model
- 2.12.4 Cloud Identity Security
- 2.12.5 Hybrid Identity Considerations
- 2.12.6 Cloud Federation Challenges
- 2.12.7 FedRAMP Implications for Federal and Military Active Directory and Entra ID Environments
- 2.13 Defense Industrial Base (DIB) and Cybersecurity Maturity Model Certification (CMMC)
 - 2.13.1 Defense Industrial Base (DIB) Cybersecurity Requirements
 - 2.13.2 Controlled Unclassified Information (CUI)
 - 2.13.3 The NIST SP 700-171
 - 2.13.4 Cybersecurity Maturity Model Certification (CMMC)
 - 2.13.5 Contractor Identity Management Requirements
 - 2.13.6 Supply Chain Identity and Risk Management
 - 2.13.7 Federal and Military Active Directory Security Considerations for Contractors and Third Parties
- 2.14 From Policy to Technical Control: How Governance Influences Federal and Military Active Directory Security
 - 2.14.1 Laws
 - 2.14.2 Policies and Procedures
 - 2.14.3 Standards
 - 2.14.4 Frameworks
 - 2.14.5 Security Controls
 - 2.14.6 Technical Implementations
 - 2.14.7 Active Directory Security Baselines
 - 2.14.8 Identity Security Enforcement Mechanisms
 - 2.14.9 Governance-to-Configuration Traceability Matrix
- 2.15 Case Study: How a Federal Cybersecurity Requirement Becomes an Active Directory Security Control
 - 2.15.1 Executive Requirements Issued
 - 2.15.2 Policy, Procedures, and Standards Development and Interpretation
 - 2.15.3 NIST Guidance Creation
 - 2.15.4 Risk Management Framework (RMF) Control Selection and the NIST SP 800-37, Revision 2
 - 2.15.5 STIG and Technical Baseline Development
 - 2.15.6 Active Directory Engineering Implementation
 - 2.15.7 Assessment and Validation
 - 2.15.8 Continuous Monitoring (ConMon), Logging, and Compliance Reporting Schedules
 - 2.15.9 Lessons Learned

INCLUDED FIGURES

- Figure 2-1. Federal Cybersecurity Governance Hierarchy
- Figure 2-2. Relationship Between Congress, OMB, NIST, CISA, and Federal Agencies
- Figure 2-3. DoD Cybersecurity Governance Structure
- Figure 2-4. Federal Identity Governance Ecosystem
- Figure 2-5. Governance-to-Technical-Control Lifecycle
- Figure 2-6. Policy-to-Active Directory Implementation Flow

INCLUDED TABLES

Table 2-1. Major Federal Cybersecurity Authorities and Responsibilities

Table 2-2. Key Federal Cybersecurity Laws and Their Impact on Identity Security

Table 2-3. NIST Publications Relevant to Federal and Military Active Directory and FICAM Environments

Table 2-4. DoD Organizations Directly Influencing Identity Security Programs

Table 2-5. Governance Requirements Mapped to Active Directory Security Controls

Table 2-6. Federal Identity Stakeholders and Their Shared Responsibilities